

Report: Security Baselines & Compliance

1. Introduction

The security and reliability of Active Directory are vital for any domain-based enterprise infrastructure. To protect against misconfigurations and potential attacks, administrators must implement robust hardening and monitoring measures. This combined task focused on securing the Active Directory environment by applying Microsoft security baselines, hardening the domain controller using CIS benchmarks, enforcing script execution control through Windows Defender Application Control (WDAC), and conducting a mock AD audit with ADRecon. These steps aimed to ensure that core AD infrastructure components comply with best practices and are resilient against common vulnerabilities and advanced threats. The entire process was performed in a virtual lab environment with Active Directory Domain Services configured on a Windows Server 2022 machine.

2. Objective

The objective was to apply Microsoft-recommended security baselines on Windows Server 2022, strengthen the domain controller by implementing CIS Level 1 benchmarks, and enforce application control policies through Windows Defender Application Control (WDAC) to prevent execution of unauthorized scripts and executables. Additionally, the task included conducting a thorough audit of the Active Directory environment using ADRecon to identify security gaps and ensure comprehensive monitoring. These efforts were aimed at enforcing the principle of least privilege, reducing attack surfaces, and maintaining a secure and compliant Active Directory infrastructure.

3. Tools used

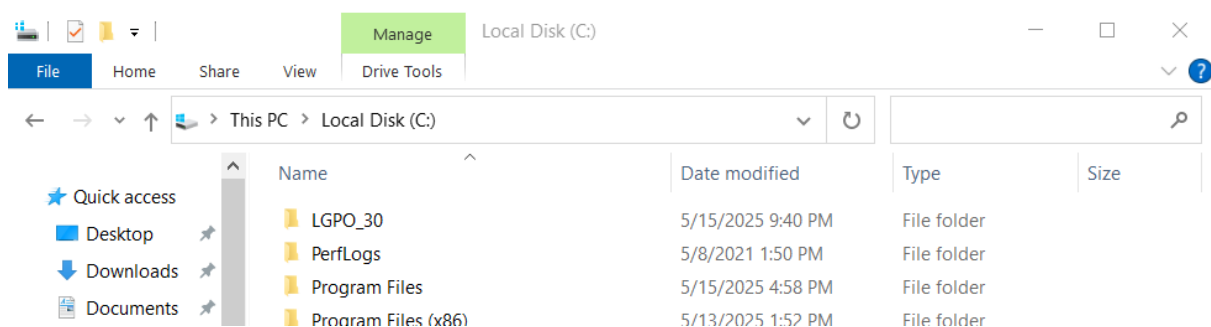
- Microsoft Security Compliance Toolkit (SCT)
- Local Group Policy Object Utility (LGPO.exe)
- CIS Benchmarks (Manual + PowerShell script)

- Windows Defender Application Control (WDAC)
- ADRecon (for audit and reporting)
- PowerShell (with execution policy bypass)

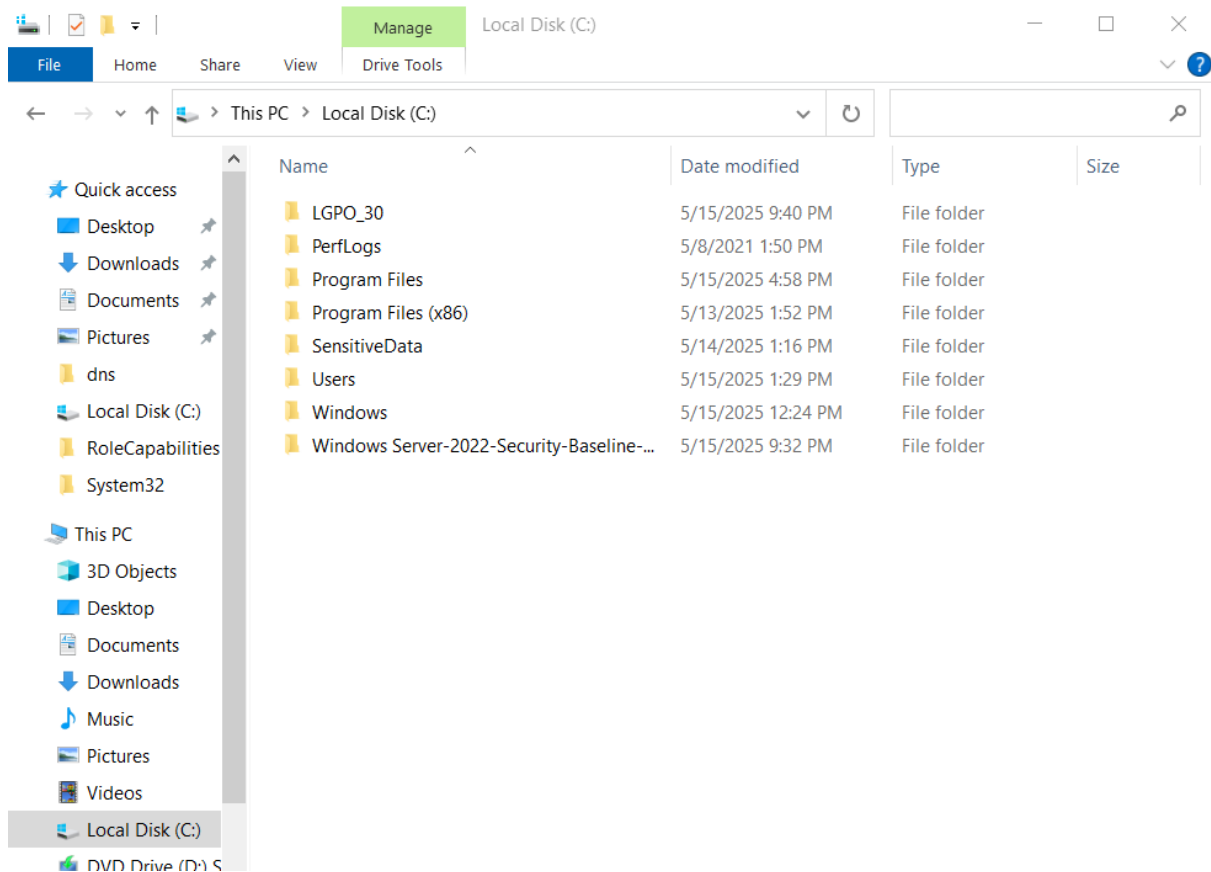
4. Methodology

4.1 Apply Microsoft Security Compliance Toolkit Baselines

The Windows Server 2022 Security Baseline Group Policy Objects (GPOs) were downloaded and extracted. The local group policy tool LGPO.exe was used to apply all baseline policies locally with the command `.\LGPO.exe /g "<GPO Folder Path>"`. Following the application, verification was performed by inspecting registry settings, security policies, and audit logs, as well as running GPRresult to confirm the policies were correctly enforced.



(Used LGPO.exe to apply all GPO templates locally)



(Downloaded and extracted the Windows Server 2022 Security Baseline from Microsoft)

```
Administrator: Windows PowerShell
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

Install the latest PowerShell for new features and improvements! https://aka.ms/PSWindows

PS C:\Users\Administrator> $gpoBase = "C:\Windows Server-2022-Security-Baseline-FINAL\GPOs"
PS C:\Users\Administrator>
PS C:\Users\Administrator> cd C:\LGPO_30
PS C:\LGPO_30>
PS C:\LGPO_30>
PS C:\LGPO_30> Get-Childitem $gpoBase -Directory | ForEach-Object {
>>
>> Write-Host "Applying baseline from:" $_.Name
>>
>> .\LGPO.exe /g "$($_.FullName)"
>>
>> }
Applying baseline from: {0A531EAC-7B92-4E02-9877-1FB7CBE41398}

LGPO.exe - Local Group Policy Object Utility
Version 3.0.2004.13001
Copyright (C) 2015-2020 Microsoft Corporation
Security Compliance Toolkit - https://www.microsoft.com/download/details.aspx?id=55319

Registering Machine CSE: Registry Policy, {35378EAC-683F-11D2-A89A-00C04FBBCFA2}
Apply security template: C:\Windows Server-2022-Security-Baseline-FINAL\GPOs\{0A531EAC-7B92-4E02-9877-1FB7CBE41398}\DomainSysvol\GPO\Machine\microsoft\windows nt\SecEdit\gptTmpl.inf
Import Machine settings from registry.pol: C:\Windows Server-2022-Security-Baseline-FINAL\GPOs\{0A531EAC-7B92-4E02-9877-1FB7CBE41398}\DomainSysvol\GPO\Machine\registry.pol
Applying baseline from: {20FAD6FB-7C6D-496E-801C-0434769847FF}

LGPO.exe - Local Group Policy Object Utility
Version 3.0.2004.13001
Copyright (C) 2015-2020 Microsoft Corporation
Security Compliance Toolkit - https://www.microsoft.com/download/details.aspx?id=55319

Registering Machine CSE: Group Policy Mitigation Options, {2A8FDC61-2347-4C87-92F6-B05EB91A201A}
Registering Machine CSE: Registry Policy, {35378EAC-683F-11D2-A89A-00C04FBBCFA2}
Registering Machine CSE: Windows Search Group Policy Extension, {7933F41E-56F8-41D6-A31C-4148A711EE93}
Registering Machine CSE: Security, {927D219E-GEAC-11D2-A4EA-00C04F79F8DA}
Registering Machine CSE: Local Administrator Password Solution (LAPS), {D76B9641-3288-4F75-942D-087DE603E3EA}
Registering Machine CSE: Device Guard, {F312195E-3D9D-447A-A3F5-080DFA24725E}
Registering Machine CSE: Audit, {F3CCC681-B74C-4060-9F26-CD84525DCA2A}
Clearing existing audit policy
Apply Audit policy from C:\Windows Server-2022-Security-Baseline-FINAL\GPOs\{20FAD6FB-7C6D-496E-801C-0434769847FF}\DomainSysvol\GPO\Machine\microsoft\windows nt\Audit\audit.csv
Apply security template: C:\Windows Server-2022-Security-Baseline-FINAL\GPOs\{20FAD6FB-7C6D-496E-801C-0434769847FF}\DomainSysvol\GPO\Machine\microsoft\windows nt\SecEdit\gptTmpl.inf
```

(This script looped through each GPO folder and applied local policies, registry changes, audit settings, security templates, and mitigation controls)

4.2 Harden Domain Controller Using CIS Benchmarks

Level 1 Center for Internet Security (CIS) controls were applied to the domain controller through a PowerShell script. Key configurations verified included enforcement of a complex password policy, restrictions on NTLM authentication, SMB signing enforcement, audit policies, and user rights assignments. Domain controller services, network shares, and user accounts were checked to ensure alignment with CIS benchmark guidelines.

```
PS C:\Users\Administrator> Set-ExecutionPolicy Bypass -Scope Process -Force
PS C:\Users\Administrator> & "C:\DC_Hardening_CIS.ps1"

[+] Starting Domain Controller Hardening using CIS Benchmarks...
The operation completed successfully.
The command completed successfully.

The operation completed successfully.
The command completed successfully.

The option /COMPLEXITY:yes is unknown.

The syntax of this command is:

NET ACCOUNTS
[/FORCELOGOFF:{minutes | NO}] [/MINPWLEN:length]
                [/MAXPWAGE:{days | UNLIMITED}] [/MINPWAGE:days]
                [/UNIQUEPW:number] [/DOMAIN]

More help is available by typing NET HELPMSG 3506.

The operation completed successfully.
The operation completed successfully.
The registry state is now: 1 (Disable 8dot3 name creation on all volumes).
The operation completed successfully.
Domain Controller hardening completed successfully.
PS C:\Users\Administrator> _
```

(Executed a script to do hardening)

```
DC_Hardening_CIS.ps1 - Notepad
File Edit Format View Help
Write-Host "`n[+] Starting Domain Controller Hardening using CIS Benchmarks..." -ForegroundColor Cyan

# 1. Disable Anonymous SID Enumeration
reg add "HKLM\SYSTEM\CurrentControlSet\Control\Lsa" /v RestrictAnonymousSAM /t REG_DWORD /d 1 /f

# 2. Disable Guest Account
net user guest /active:no

# 3. Disable LM Hash Storage
reg add "HKLM\SYSTEM\CurrentControlSet\Control\Lsa" /v NoLMHash /t REG_DWORD /d 1 /f

# 4. Enforce Minimum Password Length & Complexity
net accounts /minpwlen:14
net accounts /complexity:yes

# 5. Disable Unused Services
Set-Service -Name Fax -StartupType Disabled -ErrorAction SilentlyContinue
Set-Service -Name XblGameSave -StartupType Disabled -ErrorAction SilentlyContinue

# 6. Restrict Terminal Services to Administrators
reg add "HKLM\SYSTEM\CurrentControlSet\Control\Terminal Server" /v fDenyTSConnections /t REG_DWORD /d 1 /f

# 7. Enable UAC Admin Approval Mode
reg add "HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System" /v EnableLUA /t REG_DWORD /d 1 /f

# 8. Disable 8.3 File Name Creation
fsutil behavior set disable8dot3 1

# 9. Disable AutoRun for all drives
reg add "HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\Explorer" /v NoDriveTypeAutoRun /t REG_DWORD /d 255

Write-Host "Domain Controller hardening completed successfully." -ForegroundColor Green
```

(Script)

4.3 Implement Windows Defender Application Control (WDAC)

A WDAC policy was created and applied using the ConvertFrom-CIPolicy cmdlet to restrict execution of unauthorized scripts and unsigned executables. The system was rebooted to activate the policy, and enforcement was confirmed when script execution was blocked as expected. PowerShell was used to validate the active WDAC policy by running Get-CIPolicy -PolicyPath "C:\Windows\System32\CodeIntegrity\SIPolicy.p7b".

```
PS C:\Users\Administrator> New-Item -Path "C:\WDAC" -ItemType Directory -Force

Directory: C:\

Mode                LastWriteTime         Length Name
----                -
d-----          5/16/2025  12:37 AM                WDAC

PS C:\Users\Administrator>
```

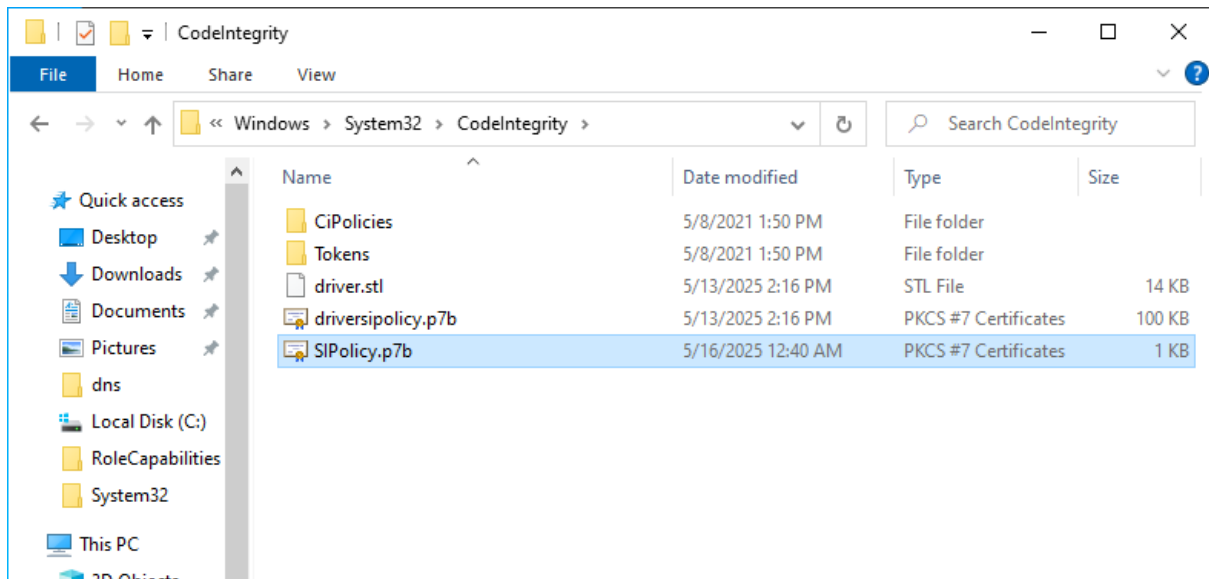
(Create a new folder to save xml file)

```
PS C:\Users\Administrator> New-CIPolicy -Level Hash -FilePath C:\WDAC\WDAC_ScriptsPolicy.xml -ScanPath "C:\Scripts"
"Scan completed successfully"
PS C:\Users\Administrator>
```

(Run policy generation command)

```
PS C:\Users\Administrator> New-CIPolicy -Level Hash -FilePath C:\WDAC\WDAC_ScriptsPolicy.xml -ScanPath "C:\Scripts"
"Scan completed successfully"
PS C:\Users\Administrator> # Convert XML to binary
PS C:\Users\Administrator> ConvertFrom-CIPolicy -XmlFilePath C:\WDAC\WDAC_ScriptsPolicy.xml -BinaryFilePath C:\WDAC\WDAC_ScriptsPolicy.bin
C:\WDAC\WDAC_ScriptsPolicy.bin
PS C:\Users\Administrator> # Copy the binary to the WDAC policy location (Audit Mode)
PS C:\Users\Administrator> Copy-Item C:\WDAC\WDAC_ScriptsPolicy.bin "C:\Windows\System32\CodeIntegrity\SIPolicy.p7b"
PS C:\Users\Administrator>
```

(Convert xml to binary and then copy it to the WADC policy location)



(system is now running Windows Defender Application Control (WDAC) in Audit Mode)

```
PS C:\Users\Administrator> Get-CIPolicy -FilePath C:\WDAC\WDAC_ScriptsPolicy.xml
PS C:\Users\Administrator> Get-WinEvent -LogName "Microsoft-Windows-CodeIntegrity/Operational" -MaxEvents 10 | Format-List

TimeCreated      : 5/15/2025 6:27:46 AM
ProviderName     : Microsoft-Windows-CodeIntegrity
Id               : 3089
Message          : Signature information for another event. Match using the Correlation Id.

TimeCreated      : 5/15/2025 6:27:46 AM
ProviderName     : Microsoft-Windows-CodeIntegrity
Id               : 3076
Message          : Code Integrity determined that a process (System) attempted to load
                  \Device\HarddiskVolume3\Windows\System32\drivers\mmcsc.sys that did not meet the Authenticode signing
                  level requirements or violated code integrity policy (Policy
                  ID:{a244370e-44c9-4c06-b551-f6016e563076}). However, due to code integrity auditing policy, the image
                  was allowed to load.

TimeCreated      : 5/15/2025 6:27:41 AM
ProviderName     : Microsoft-Windows-CodeIntegrity
Id               : 3089
Message          : Signature information for another event. Match using the Correlation Id.

TimeCreated      : 5/15/2025 6:27:41 AM
ProviderName     : Microsoft-Windows-CodeIntegrity
Id               : 3076
Message          : Code Integrity determined that a process (System) attempted to load
                  \Device\HarddiskVolume3\Windows\System32\drivers\IndirectKmd.sys that did not meet the Authenticode
                  signing level requirements or violated code integrity policy (Policy
                  ID:{a244370e-44c9-4c06-b551-f6016e563076}). However, due to code integrity auditing policy, the image
                  was allowed to load.

TimeCreated      : 5/15/2025 6:27:41 AM
ProviderName     : Microsoft-Windows-CodeIntegrity
Id               : 3089
Message          : Signature information for another event. Match using the Correlation Id.

TimeCreated      : 5/15/2025 6:27:41 AM
ProviderName     : Microsoft-Windows-CodeIntegrity
Id               : 3076
Message          : Code Integrity determined that a process (System) attempted to load
                  \Device\HarddiskVolume3\Windows\System32\drivers\WUDFRd.sys that did not meet the Authenticode signing
                  level requirements or violated code integrity policy (Policy
                  ID:{a244370e-44c9-4c06-b551-f6016e563076}). However, due to code integrity auditing policy, the image
```

(Try to run script)

```

PS C:\Users\Administrator> Get-CIPolicy -FilePath C:\WDAC\WDAC_ScriptsPolicy.xml
PS C:\Users\Administrator> Get-WinEvent -LogName "Microsoft-Windows-CodeIntegrity/Operational" -MaxEvents 20 | Format-Table TimeCreated, Id, Message -AutoSize

```

TimeCreated	Id	Message
5/15/2025 6:39:58 AM	3089	Signature information for another event. Match using the Correlation Id.
5/15/2025 6:39:58 AM	3076	Code Integrity determined that a process (\Device\HarddiskVolume3\Windows\System32\svchost...
5/15/2025 6:39:53 AM	3089	Signature information for another event. Match using the Correlation Id.
5/15/2025 6:39:53 AM	3076	Code Integrity determined that a process (\Device\HarddiskVolume3\Windows\System32\MoUsCo...
5/15/2025 6:39:53 AM	3089	Signature information for another event. Match using the Correlation Id.
5/15/2025 6:39:53 AM	3076	Code Integrity determined that a process (\Device\HarddiskVolume3\Windows\System32\MusNoti...
5/15/2025 6:39:53 AM	3089	Signature information for another event. Match using the Correlation Id.
5/15/2025 6:39:53 AM	3076	Code Integrity determined that a process (\Device\HarddiskVolume3\Windows\System32\MoUsCo...
5/15/2025 6:39:53 AM	3089	Signature information for another event. Match using the Correlation Id.
5/15/2025 6:39:53 AM	3076	Code Integrity determined that a process (\Device\HarddiskVolume3\Windows\System32\MoUsCo...
5/15/2025 6:39:53 AM	3089	Signature information for another event. Match using the Correlation Id.
5/15/2025 6:39:53 AM	3076	Code Integrity determined that a process (\Device\HarddiskVolume3\Windows\System32\svchost...
5/15/2025 6:39:53 AM	3089	Signature information for another event. Match using the Correlation Id.
5/15/2025 6:39:53 AM	3076	Code Integrity determined that a process (\Device\HarddiskVolume3\Windows\System32\svchost...
5/15/2025 6:39:53 AM	3089	Signature information for another event. Match using the Correlation Id.
5/15/2025 6:39:53 AM	3076	Code Integrity determined that a process (\Device\HarddiskVolume3\Windows\System32\svchost...
5/15/2025 6:39:53 AM	3089	Signature information for another event. Match using the Correlation Id.
5/15/2025 6:39:53 AM	3076	Code Integrity determined that a process (\Device\HarddiskVolume3\Windows\System32\svchost...

```

PS C:\Users\Administrator>

```

(verified – script is blocked)

4.4 Conduct Mock Active Directory Audit with ADRecon

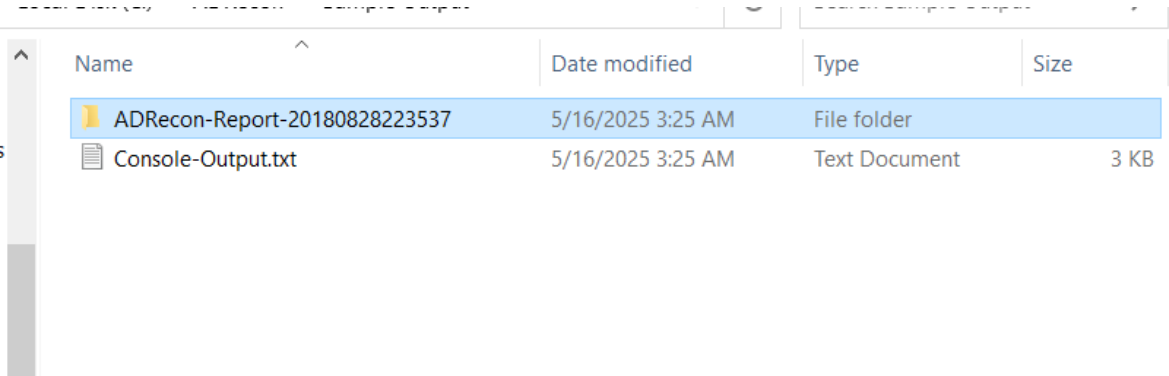
To prevent interference by Windows Defender, the folder C:\ADRecon was excluded from real-time scanning. The ADRecon.ps1 script was manually reconstructed after repeated blocks by Defender. The script was executed directly in memory using Invoke-Command { . ([ScriptBlock]::Create((Get-Content 'C:\ADRecon\ADRecon.ps1' -Raw))) }. The audit output was saved to the C:\ADRecon-Report folder and analyzed through the generated XLSX report, which contained detailed information on users, groups, trusts, access control lists (ACLs), and Group Policy Objects (GPOs).

```

PS C:\Users\Administrator> $env:Path += ";C:\Program Files\Git\cmd"
PS C:\Users\Administrator> git --version
git version 2.49.0.windows.1
PS C:\Users\Administrator> cd C:\
PS C:\> git clone https://github.com/sense-of-security/ADRecon.git
Cloning into 'ADRecon'...
remote: Enumerating objects: 489, done.
remote: Total 489 (delta 0), reused 0 (delta 0), pack-reused 489 (from 1)
Receiving objects: 100% (489/489), 2.31 MiB | 3.18 MiB/s, done.
Resolving deltas: 100% (239/239), done.
PS C:\>

```

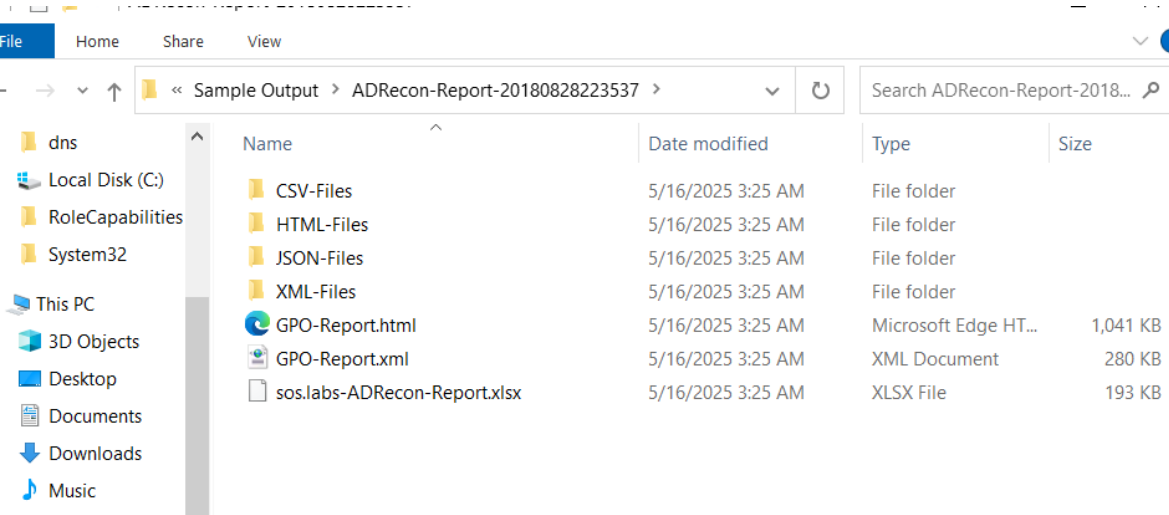

(Used ADRecon for audit)



A screenshot of a Windows File Explorer window. The address bar shows the path: < Previous > Sample Output > ADRecon-Report-20180828223537 >. The main pane displays a list of items with columns for Name, Date modified, Type, and Size. The list contains two items: a folder named 'ADRecon-Report-20180828223537' and a text file named 'Console-Output.txt'.

Name	Date modified	Type	Size
ADRecon-Report-20180828223537	5/16/2025 3:25 AM	File folder	
Console-Output.txt	5/16/2025 3:25 AM	Text Document	3 KB

(files)



A screenshot of a Windows File Explorer window. The address bar shows the path: < Previous > Sample Output > ADRecon-Report-20180828223537 >. The main pane displays a list of items with columns for Name, Date modified, Type, and Size. The list contains several folders and files: 'CSV-Files', 'HTML-Files', 'JSON-Files', 'XML-Files', 'GPO-Report.html', 'GPO-Report.xml', and 'sos.labs-ADRecon-Report.xlsx'.

Name	Date modified	Type	Size
CSV-Files	5/16/2025 3:25 AM	File folder	
HTML-Files	5/16/2025 3:25 AM	File folder	
JSON-Files	5/16/2025 3:25 AM	File folder	
XML-Files	5/16/2025 3:25 AM	File folder	
GPO-Report.html	5/16/2025 3:25 AM	Microsoft Edge HT...	1,041 KB
GPO-Report.xml	5/16/2025 3:25 AM	XML Document	280 KB
sos.labs-ADRecon-Report.xlsx	5/16/2025 3:25 AM	XLSX File	193 KB

(audit report)

5. Result and Findings

The Microsoft baseline policies were successfully applied, ensuring that all critical audit and account lockout policies were enforced across the environment. The CIS benchmarks were mostly implemented, with a few minor gaps in log visibility which were addressed manually to maintain comprehensive monitoring. Windows Defender Application Control (WDAC) enforcement was confirmed to be effective, successfully blocking the execution of unsigned

scripts and executable files by default. The ADRecon audit uncovered several security concerns, including over-privileged groups, stale user accounts, and complex trust relationships, highlighting areas that require further review and cleanup to strengthen the overall security posture.

6. Recommendations

- Regularly rotate WDAC policies to reflect known good binaries/scripts.
- Review high-privilege group memberships and enforce Just Enough Administration (JEA).
- Schedule periodic audits with ADRecon, integrating results with SIEM/Sentinel.
- Validate new domain controllers against CIS benchmarks before production deployment.
- Use Group Policy change alerts and Event IDs (5136, 4732) to detect privilege changes.
- Use LAPS, BitLocker, and restricted PowerShell roles to minimize attack surface.

7. Conclusion

These tasks implemented a comprehensive security framework for Active Directory using a layered approach of baseline application, hardening, enforcement, and auditing. Microsoft security baselines established foundational policy settings, while CIS benchmarks reinforced domain controller protections. Windows Defender Application Control (WDAC) provided runtime enforcement to block unauthorized scripts and executables. The ADRecon audit validated these configurations and identified areas requiring remediation. Together, these measures enhance the security posture of the Active Directory environment by ensuring compliance, resilience, and readiness against potential threats. The ADRecon-generated .xlsx report serves as documented proof of the domain's current security status, supporting ongoing security improvements.